

 የኢንፎርሜሽን መረብ ደህንነት አስተዳደር Information Network Security Administration	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No. 1	Page No.: Page 1 of 22



Cybersecurity Audit minimum Requirements Document

For Electronic Invoice Machine, ERP & POS Device Security

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No. 1	Page No.: Page 2 of 22

Table of Contents

1. Purpose	4
2. Scope of security audit	5
3. Définitions.....	5
4. Security Requirements	6
4.1 Secure Boot	6
4.2 Firmware & Software Integrity	8
4.3. Hardware Security	8
4.4. Data Security.....	9
4.5 . Secure Communication.....	10
4.6 Access Control	11
4.7 . Secure Provisioning & Key Management	12
4.8. OTA Updates.....	13
4.9 Device Lockdown	14
4.10 Fiscal Data Protection	14
4.11 ERP & POS Integration Security	15
5. Testing & Validation	17
5.1 Penetration Testing	17
5.2 Compliance Auditing.....	19
6. Conclusion.....	22

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No.: 1	Page No.: Page 3 of 22

Warning

All requirements are mandatory to achieve national security objectives. Testers must strictly adhere to authorized scopes and requirements to ensure no critical areas are missed during testing. Testing must never compromise system integrity, availability, or data confidentiality. Complete coverage of all security controls and accurate documentation of findings are essential to avoid false security assurances. Careful precautions should be taken to prevent accidental data loss or exposure, with clear communication maintained with stakeholders throughout the testing process.

Developer/Customers are concerned about falsification functionality and related statements when preparing requirements. Anyone intending to participate in testing must ensure that all software and hardware functionalities are ready in accordance with compliance requirements. Any request or submission that does not align with the following requirements will not be accepted.

Customer /developer should be provide Software Requirements Specification (SRS) document it is a detailed blueprint that describes what a software system will do, how it will perform, and the conditions under which it will operate. It typically begins with an introduction outlining the purpose, scope, definitions, references, and document overview. This is followed by an overall description that explains the system's context, main functions, user roles, operating environment, constraints, and assumptions. The document then details system features through specific functional requirements, followed by descriptions of external interfaces such as user, hardware, software, and communication connections. It also defines nonfunctional requirements, including performance, security, reliability, maintainability, and portability, as well as any legal, regulatory, or compliance needs.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 4 of 22

1. Purpose

This document defines the Cybersecurity and hardware security requirements, outlining the rules and technical measures necessary to protect devices and systems from Cyberattacks and physical tampering. It focuses on three core components: electronic invoice machines, ERP systems, and POS devices. Electronic invoice machines are devices used by businesses to generate and transmit invoices, often integrated with government revenue systems to ensure accurate tax reporting. ERP systems are software platforms that manage critical business functions, including accounting, inventory, and financial operations, providing centralized control over enterprise processes. POS devices, on the other hand, serve as front, end systems where payments are processed, connecting business operations directly to customer transactions. Together, these components form an interconnected ecosystem that requires strong security measures to safeguard data and ensure reliable, tamper, proof operation.

❖ Purpose of the Requirements:

- **Protection of sensitive fiscal, financial, and customer data** making sure that tax, related data, transaction records, and customer information are kept confidential and safe from breaches.
- **Prevention of unauthorized firmware, software, or hardware modifications** ensuring no one can alter the system software, inject malicious code, or physically tamper with the devices.
- **Security of communications between devices and enterprise systems** ensuring all data transferred (like invoices, payment details, and ERP records) is encrypted and protected from interception or manipulation.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 5 of 22

- **Compliance with applicable standards and fiscal regulations** making sure that the system adheres to legal requirements, industry standards, and government mandates for financial data security.

2. Scope of security audit

This document applies to:

- **Electronics Invoice Machines:** Hardware devices specifically designed to securely generate and transmit fiscal invoices, ensuring compliance with tax regulations and accurate revenue reporting.
- **ERP (Enterprise Resource Planning) Systems:** Integrated software platforms used by organizations to manage and automate core business processes, including invoicing, inventory management, and accounting, to improve operational efficiency and data accuracy.
- **POS (Point,of,Sale) Devices:** Front,end systems used to process customer payments and sales transactions, often integrated with invoicing machines and ERP systems to maintain real, time financial and inventory records.
- **Peripheral Components:** Additional hardware and software elements that interact with invoicing devices, such as printers, scanners, card readers, or communication modules, which support or enhance the overall functionality of the system.

3. Définitions

- **Secure Boot:** A security mechanism that ensures only trusted and digitally signed firmware is executed during the device's startup process, protecting against unauthorized or malicious code.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 6 of 22

- **TLS (Transport Layer Security):** A cryptographic protocol used to secure data transmission over networks, providing encryption, integrity, and authentication to prevent interception or tampering.
- **ERP (Enterprise Resource Planning):** Software used to manage and integrate core business processes, such as accounting, inventory, procurement, and human resources, within a unified platform.
- **POS (Point,of,Sale):** A system used for handling customer transactions and payment processing, often integrated with inventory and financial systems for accurate sales tracking.
- **OTA (Over,the,Air Updates):** A method of remotely delivering and installing software or firmware updates to devices without requiring physical access, enhancing maintainability and security.
- **Third Party Software:** Third,party software refers to any computer program developed by a company other than the original manufacturer or provider of the operating system or hardware.

4. Security Requirements

4.1 Secure Boot

Devices must implement a **secure boot** mechanism to guarantee that only firmware that has been cryptographically signed and authorized by the trusted authority can be executed during the device startup. This prevents unauthorized, tampered, or malicious firmware from running on the device, thereby protecting the device's integrity and security from the very first instruction executed after power,on or reset

Requirement:

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 7 of 22

- Devices must implement secure boot to ensure that only cryptographically signed and authorized firmware executes.

Controls:

- Bootloader must verify firmware digital signatures using a hardware,protected key.
- Boot process must halt if signature verification fails.
- Attempted bypass (e.g., glitching attacks) must be detected and logged.

Controls:

- **Firmware Digital Signature Verification:** The bootloader, which is the first code executed during device startup, must verify the authenticity and integrity of the firmware by checking its digital signature. This verification process uses a cryptographic key that is securely stored in hardware, such as in a Trusted Platform Module (TPM), Secure Element, or secure enclave, to prevent unauthorized access or extraction. The signature ensures that the firmware has not been altered and was signed by a legitimate source.
- **Boot Process Enforcement:** If the bootloader detects that the firmware signature is invalid, missing, or corrupted, the boot process must immediately stop. This halting of the boot prevents the device from running any unauthorized or potentially harmful code. This control acts as a strong gatekeeper, ensuring that only verified software can control the device.
- **Bypass Attempt Detection and Logging:** Attackers might attempt to bypass secure boot protections using advanced fault injection techniques, such as voltage glitching or clock manipulation, to skip signature verification steps or force the device to run unauthorized code. The device must have mechanisms to detect such tampering attempts. When an attempt is detected, it should be logged securely, providing an audit trail that can be used for forensic analysis and incident response. This logging can also trigger alerts or protective actions, such as device lockdown or reporting to a centralized security system

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 8 of 22

4.2 Firmware & Software Integrity

Requirement:

The firmware running on the device must be both encrypted and digitally signed to protect against unauthorized modification and reverse engineering. This ensures that only authentic and untampered software controls the device, safeguarding its functionality and security.

Controls:

- **Encryption of Firmware:** Firmware must be encrypted using a strong symmetric encryption algorithm, such as AES,256, to prevent unauthorized access to the code stored on the device. Encryption protects firmware confidentiality, making it extremely difficult for attackers to extract or analyze the code, even if they gain physical access to the device memory.
- **Secure Storage of Cryptographic Keys:** The cryptographic keys used for encryption and digital signature verification must be stored securely within the hardware. Devices should employ trusted hardware components such as a Trusted Platform Module (TPM), Secure Enclave, or Hardware Security Module (HSM) to protect keys from extraction or tampering. This hardware, level protection ensures that keys cannot be easily copied or compromised.
- **Firmware Hash Validation at Boot:** Every time the device boots, the bootloader must calculate a cryptographic hash of the firmware and verify it against the expected value to ensure firmware integrity. This process detects any unauthorized changes or corruption of the firmware. If the hash validation fails, the device should prevent execution of the compromised firmware and initiate protective measures, such as halting boot or triggering an alert.

4.3. Hardware Security

Requirement:

To protect the device from physical attacks and unauthorized access, all debug and programming interfaces must be securely locked or disabled. Additionally, the device must have mechanisms to detect and respond to any physical tampering attempts.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 9 of 22

Controls:

- **Secure Debug and Programming Interfaces:** Interfaces commonly used for development and troubleshooting, such as UART, JTAG, and SPI, pose significant security risks if left accessible in deployed devices. These ports must be disabled entirely or protected with strong passwords and access controls to prevent unauthorized users from gaining low, level access to the device, extracting firmware, or injecting malicious code.
- **Tamper Detection Mechanisms:** The device should be equipped with physical tamper switches, sensors, or circuits that can detect attempts to open the device casing, remove components, or interfere with the hardware. Upon detecting tampering, the device should trigger immediate responses such as erasing sensitive data, locking down operations, or sending alerts to monitoring systems.
- **Physical Protection of Sensitive Components:** Critical components, including memory chips and cryptographic modules, should be shielded using epoxy resin, metal shielding, or other tamper, resistant materials. This physical protection helps deter invasive attacks like micro probing or chip encapsulation aimed at extracting secrets or modifying hardware behavior.
- The device should have a tamper evident and/or tamper detection enabled enclosure. This will enable easy detection of attempts to physically tamper with the device aimed at altering or destroying information.

4.4. Data Security

Requirement:

All transaction and fiscal data handled by the device and associated systems must be protected through encryption both when stored (at rest) and during transmission (in transit). This ensures the confidentiality and integrity of sensitive financial information such as invoices, taxpayer identification, and transaction records.

Controls:

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No. 1	Page No.: Page 10 of 22

- **Encryption at Rest:** All stored financial and fiscal data must be encrypted using strong encryption algorithms such as AES, 256. This prevents unauthorized access to sensitive data in case the storage medium is physically compromised or stolen.
- **Encrypted Storage of Sensitive Data:** Highly sensitive information, including taxpayer IDs, invoice details, and payment data, must never be stored in plain text. Encryption ensures that even if an attacker gains access to storage, the data remains unreadable without the correct cryptographic keys.
- **Data Retention and Deletion Policies:** Data must be retained only as long as required by applicable fiscal regulations and business needs. Secure deletion mechanisms should be implemented to irreversibly remove data when it is no longer necessary, protecting against unauthorized recovery or misuse

4.5. Secure Communication

Requirement:

All communications between devices, ERP systems, and POS systems must be encrypted and authenticated to ensure that sensitive financial and transactional information is protected from interception, unauthorized access, or manipulation during transmission.

Controls:

- **Use TLS 1.3 or above:** All data transmitted over the network must use secure communication protocols such as **TLS 1.3** or newer. This ensures encryption of the data in transit, preventing eavesdropping and man,in,the,middle (MITM) attacks, while also providing data integrity and confidentiality.
- **Certificate, Based Mutual Authentication:** Both clients (POS, invoicing devices) and servers (ERP backend) must authenticate each other using digital certificates. Mutual TLS

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No. 1	Page No.: Page 11 of 22

(mTLS) ensures that only trusted devices and servers communicate, blocking unauthorized or rogue devices from connecting to the network.

- **Disable Insecure Protocols:** Outdated and insecure protocols such as **HTTP, Telnet, and FTP** must be disabled entirely. These protocols transmit data in plain text and are vulnerable to interception, credential theft, and session hijacking. Only secure, encrypted protocols must be allowed in the production environment.

4.6 Access Control

Requirement:

Access to device administration, ERP systems, and POS applications must be role-based and protected by strong authentication mechanisms. This ensures that only authorized personnel can access specific system functionalities, minimizing the risk of unauthorized changes, data breaches, or fraud.

Controls:

- **Multi-Factor Authentication (MFA):** Administrative access to devices, ERP systems, and POS platforms must require at least two forms of authentication (e.g., password + hardware token, biometric verification, or one-time code). MFA significantly reduces the risk of unauthorized access, even if user credentials are compromised.
- **Session Management & Account Lockouts:** Systems must enforce configurable session timeouts to automatically log out users after periods of inactivity, reducing exposure to unattended terminals. Additionally, account lockouts must be triggered after a predefined number of failed login attempts to protect against brute force and credential stuffing attacks.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 12 of 22

- Role,Based Access Control (RBAC): User roles must be clearly defined and separated into categories such as operators, administrators, and auditors. Each role must have access only to the functions required for their job responsibilities. For example, operators can process sales, administrators can configure systems, and auditors can view logs but not alter settings.

4.7 . Secure Provisioning & Key Management

Requirement:

All cryptographic keys used by devices must be securely generated, provisioned, and stored to ensure data confidentiality, integrity, and authenticity. This prevents unauthorized access, tampering, and misuse of sensitive cryptographic materials.

Controls:

- Secure Key Injection during Manufacturing: Cryptographic keys must be securely injected into devices at the time of manufacturing using a Hardware Security Module (HSM) or equivalent trusted secure process. This prevents key exposure during production and ensures keys are not compromised before the device is deployed.
- Unique Device Keys: Each device must have its own unique cryptographic keys rather than shared or default keys across multiple devices. Unique keys minimize the impact of a single device compromise, preventing attackers from using one leaked key to compromise other devices in the network.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 13 of 22

- **Secure Key Rotation and Revocation:** The system must support secure key rotation to periodically update cryptographic keys without service disruption. Additionally, secure key revocation mechanisms must be in place to immediately invalidate compromised or outdated keys, ensuring continued protection of communications and stored data.

4.8. OTA Updates

Requirement:

Over, the, Air (OTA) updates must be secure, authenticated, and integrity, protected to ensure that only authorized, verified, and untampered firmware or software packages are delivered and installed on devices. This prevents malicious updates, unauthorized code injection, and rollback attacks that could compromise device security and functionality.

Controls:

- **Digitally Signed & Encrypted Updates:** All OTA update packages must be digitally signed using a trusted private key to verify authenticity and encrypted to maintain confidentiality during transmission. This ensures that only firmware released by authorized sources can be installed.
- **Signature & Version Validation:** The device must verify the digital signature and check the version number of the update package before installation. Updates failing signature validation or attempting to downgrade firmware to an older version must be rejected.
- **Anti,Rollback Mechanism:** The device must implement anti,rollback protections to prevent the installation of older, potentially vulnerable firmware versions. This ensures that attackers cannot exploit known security weaknesses in outdated software.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 14 of 22

- Logging of Update Activities: All OTA update events, including initiation, package verification, and installation, failures, and version changes, must be securely logged. This provides traceability for audit, incident response, and compliance verification.

4.9 Device Lockdown

Requirement:

All deployed devices (e.g., POS terminals, ERP access terminals, cash registers) must be locked down to prevent unauthorized installation, execution, or alteration of software and configuration settings. This requirement ensures that only approved software and firmware are used, eliminating the risk of malicious code execution and ensuring operational integrity.

Controls:

- Vendor, Approved Applications Only
 - Implement application whitelisting that restricts execution to pre-approved vendor, supplied and digitally signed applications.
 - Disable execution of scripts, macros, and unverified binaries by default.
- Restricted Command, Line and Scripting Access
 - Remove or disable user access to command, line interfaces (e.g., PowerShell, Bash, and CMD) unless explicitly required for administrative functions.
 - Apply access control policies preventing execution of unauthorized scripts or commands.
- Enforce Least Privilege
 - Configure all device processes and services to run with the minimum privileges necessary for functionality.
 - Regularly review user accounts and services to ensure no unnecessary elevated privileges exist.
 - Implement strong endpoint management policies and regularly audit device compliance.

4.10 Fiscal Data Protection

Requirement:

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 15 of 22

All fiscal data including invoices, transaction logs, and tax records must be safeguarded against forgery, unauthorized deletion, or manipulation. This ensures fiscal compliance, accurate reporting, and traceability for auditing purposes.

Controls:

- Immutable, Digitally Signed Invoice Logs
 - Maintain invoice logs in an immutable storage format (e.g., WORM – Write Once Read Many).
 - Digitally sign each transaction and invoice using asymmetric cryptography to ensure authenticity and non,repudiation.
- Secure Time,Stamping
 - Implement secure, cryptographic time,stampng for all fiscal transactions to ensure chronological integrity.
 - Utilize a trusted time source (e.g., NTP with authentication) to prevent time manipulation attacks.
- Secure Offline Caching
 - Ensure offline invoice storage (e.g., for disconnected POS) uses full,disk encryption and per,file integrity validation (e.g., HMAC or SHA,256).
 - Automatically synchronize cached invoices securely when connectivity is restored, ensuring data integrity and consistency.

4.11 ERP & POS Integration Security

Requirement:

The integration between ERP systems and Point,of,Sale (POS) devices must guarantee secure data transmission, confidentiality, and integrity while preventing unauthorized manipulation or fraud.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 16 of 22

Controls:

1. Secure APIs

- Use secure REST or GraphQL APIs, enforcing authentication and authorization via OAuth 2.0 or JWT with short,lived tokens.
- Enforce TLS 1.3 for encrypted data,in,transit to prevent eavesdropping or man,in,the,middle attacks.

2. Input Validation

- Implement strict input validation for all API endpoints to prevent injection vulnerabilities (e.g., SQLi, XML External Entity, command injection).
- Employ structured data formats such as JSON or XML schemas for validation and enforce content,type security headers.

3. Least Privilege Access

- Restrict ERP user roles to only the required integration functions (e.g., read,only for reporting, transaction,limited for POS updates).
- Enforce segregation of duties (SoD) between operational, financial, and administrative ERP users.

4.12 Physical Security

Requirement:

Devices handling fiscal and operational data must be physically protected against theft, tampering, or hardware,based attacks to prevent data compromise and operational disruption.

Controls:

1. Tamper,Proof Enclosures

- Use locked, tamper,evident enclosures with security seals to prevent unauthorized access to internal components.
- Maintain documented chain,of,custody for devices during transport or installation.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 17 of 22

2. Tamper Detection & Response

- Integrate tamper sensors that detect physical intrusion attempts and trigger an alert or automatic device lockdown.
- Configure devices to securely wipe sensitive data or disable functions if unauthorized tampering is detected.

3. Secure Mounting & Power Protection

- Mount devices in secure, monitored environments (e.g., bolted to counters, within locked cabinets).
- Include power backup and surge protection to mitigate voltage glitching or power interruption attacks aimed at bypassing security.

5. Testing & Validation

5.1 Penetration Testing

Objective:

To identify vulnerabilities and weaknesses in physical devices, network infrastructure, firmware, APIs, and web applications integrated with fiscal and ERP/POS systems. Testing must simulate realistic attack scenarios to validate the effectiveness of implemented security controls.

Scope & Methodology:

1. Physical Testing

- **Secure Boot Bypass Attempts:**
Attempt to tamper with or bypass secure boot configurations using hardware debug ports (e.g., JTAG, UART) to load unauthorized firmware or gain low,level access.
- **Debug Interface Exploitation:**
Identify and attempt exploitation of unprotected debugging/test interfaces that may allow unauthorized access to the operating system or memory contents.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 18 of 22

- Tamper Detection Validation:

Test the ability of tamper sensors and protective enclosures to detect physical intrusion attempts. Validate automatic lockout or alert triggering upon tamper events.

2. Network Security Testing

- Man,in,the,Middle (MITM) Attacks:

Attempt interception of POS,ERP and POS,cloud communications to verify TLS 1.3 enforcement and resistance to session hijacking.

- TLS Downgrade & Certificate Validation:

Attempt protocol downgrade attacks and test if devices correctly validate certificates (including revocation checking).

- Session Hijacking & Replay Attacks:

Attempt session token theft, replaying legitimate requests, or manipulating transaction data during transmission.

3. Firmware & Software Analysis

- Firmware Reverse Engineering:

Analyze firmware binaries for hardcoded credentials, backdoors, and unsafe coding practices. Perform static and dynamic analysis to detect security gaps.

- API & Web Application Security Testing:

Conduct OWASP Top 10 based testing of APIs and web interfaces (e.g., input validation, authentication bypass, access control flaws, injection vulnerabilities).

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 19 of 22

- Patch Management Verification:

Validate that devices support secure firmware update mechanisms, digital signature verification, and proper rollback protection.

Deliverables:

- Detailed vulnerability report with proof, of, concept (PoC) for each identified issue.
- Risk rating aligned with CVSS scoring system.
- Remediation recommendations and retesting results after fixes.

5.2 Compliance Auditing

Objective:

To ensure that the entire system, including ERP/POS integration, data handling, and device lockdown features, complies with relevant industry and local fiscal regulations.

Scope & Methodology:

1. Standards Mapping & Gap Analysis

- PCI,DSS (Payment Card Industry Data Security Standard): Validate secure handling of cardholder data, encryption of transmission, and access control compliance.
- Non,PCI,DSS (proprietary) card payment systems (loyalty cards, voucher cards, wallet cards, local payment cards, and the alike) should follow the following globally adopted security standards: *
 - Install and maintain network security controls.

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No.: 1	Page No.: Page 20 of 22

- Apply secure configurations to all system components.
- Protect stored account data.
- Protect cardholder data with strong cryptography during transmission over open, public networks.
- Protect all systems and networks from malicious software.
- Develop and maintain secure systems and software.
- Restrict access to system components and cardholder data by business need to know.
- Identify users and authenticate access to system components.
- Restrict physical access to cardholder data.
- Log and monitor all access to system components and cardholder data.
- Test security of systems and networks regularly.
- Support information security with organizational policies and programs.
- ISO/IEC 27001 (Information Security Management): Ensure information security policies, risk management, and controls are implemented and documented.
- ISO/IEC 15408 (Common Criteria for IT Security): Assess the product against defined security functional requirements (SFR) and assurance requirements (SAR).
- Local Fiscal Authority Requirements: Verify compliance with mandatory electronic invoicing laws, fiscal memory integrity, and secure reporting procedures as mandated by tax authorities.

6.Audit Deliverables

- Compliance checklist covering each relevant standard and regulation.
- Evidence,based audit report detailing compliance status and corrective action plan (if any gaps are identified).

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION		Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline		Issue No. 1	Page No.: Page 21 of 22

- Certification or attestation documents from accredited bodies where required

	Company Name: የኢንፎርሜሽን መረብ ደህንነት አስተዳደር INFORMATION NETWORK SECURITY ADMINISTRATION	Document No.: OF/AEAD/001	
	Title Cybersecurity Audit Requirements Document Guideline	Issue No.: 1	Page No.: Page 22 of 22

7. Conclusion

The security of electronic invoice machines, ERP systems, and POS devices is fundamental to safeguarding fiscal integrity, protecting sensitive data, and ensuring compliance with national and international regulations. The requirements outlined in this document are not optional, they form the baseline for achieving robust cybersecurity and operational resilience.

Every stakeholder, including developers, integrators, and testers, must recognize that incomplete or noncompliant implementations pose significant risks, including data breaches, financial fraud, operational disruption, and loss of public trust. Testing must be thorough, covering both software and hardware functionalities in full alignment with these requirements, and must never compromise the confidentiality, integrity, or availability of systems.

Falsification of functionality, results, or compliance status will not be tolerated under any circumstances. All participants in development, deployment, and auditing are responsible for ensuring truthful reporting, accurate documentation, and strict adherence to approved standards and authorized testing scopes.

By implementing these requirements in full, organizations will not only meet compliance obligations but also strengthen the resilience of critical financial systems, safeguard national revenue, and maintain trust among citizens, businesses, and regulatory bodies.